

ONEST LOGISTICS · DIRECCIÓN DE SISTEMAS & TI

Gobernanza y Funcionamiento de la Plataforma de Telemetría Web

Cómo funciona el sistema, qué protege, y qué sigue

v1.0.0-MVP · Fase 1 · Documento de presentación

✓ Privacidad por Diseño

✓ 12/12 pruebas automatizadas

✓ RBAC + k-Anonymity ≥ 5

1. Resumen ejecutivo

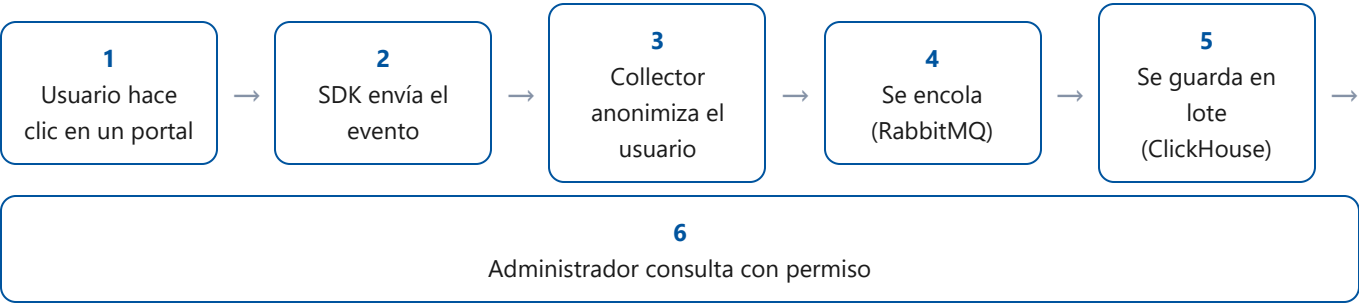
¿Qué es esta plataforma? Un sistema interno que mide cómo el personal de ONEST Logistics usa los más de 20 portales web corporativos (CRM, ERP, portal de clientes, etc.), sin identificar nunca a una persona específica.

¿Por qué importa? Permite a Dirección y a Sistemas & TI tomar decisiones (qué portales se usan poco, dónde hay errores, qué licencias están ociosas) basadas en datos reales, cumpliendo principios de protección de datos personales desde el diseño (*Privacy by Design*).

Estado actual: el sistema fue auditado internamente y **aprobado sin reservas** en protección de datos, resiliencia técnica, homologación visual y cobertura de pruebas (12/12 exitosas). Está operativo en Fase 1 (MVP).

2. Cómo funciona el portal, en una imagen

Cada clic o vista de página en un portal interno sigue esta ruta antes de convertirse en un número que ve un administrador:



2.1 Los componentes técnicos

Componente	Qué hace	Analogía simple
SDK Web	Pequeño script instalado en cada portal que registra clics y vistas de página	Como un contador de visitas discreto
Collector	Recibe los eventos y convierte el identificador de usuario en un código irreversible antes de continuar	Una recepción que quita el nombre y pone un número de folio
RabbitMQ	Cola de mensajes que evita que la ingesta se sature o se pierda si algo falla	Una fila de espera ordenada

ClickHouse	Base de datos especializada en guardar y sumar millones de eventos rápidamente	Un almacén con caducidad automática (90 días)
Aggregation API	Calcula los indicadores (KPIs) y sirve el panel visual (dashboard)	El "contador" que entrega el reporte final

3. Gobernanza y privacidad, a detalle

El sistema aplica **5 controles concretos**, cada uno verificado en la auditoría interna con evidencia de código:

3.1 Minimización de datos en el origen

El SDK nunca captura contraseñas, contenido de formularios ni texto libre. Un validador adicional (`extra=forbid`) rechaza cualquier campo no autorizado, y enmascara automáticamente correos o números largos que aparezcan por accidente en mensajes de error.

3.2 Pseudonimización irreversible

Antes de que un evento salga del Collector, el identificador del usuario se transforma con `HMAC-SHA256` (una función criptográfica de un solo sentido) más una clave secreta. **No existe forma de revertir este proceso** — no hay tabla de mapeo inverso ni endpoint para "deshacer" el hash.

3.3 Umbral de anonimato colectivo (k -anonymity ≥ 5)

Ningún reporte muestra datos de un grupo con menos de 5 usuarios únicos. Si un portal tiene, por ejemplo, solo 3 usuarios activos, el sistema oculta automáticamente esas cifras en vez de exponerlas — así nunca se puede aislar el comportamiento de una sola persona por descarte.

3.4 Retención limitada de datos

Los eventos crudos se eliminan automáticamente después de **90 días** (configurado directamente en la base de datos, sin depender de que alguien lo haga manualmente).

3.5 Control de acceso por rol (RBAC)

Cada consulta exige un rol autorizado (`ejecutivo` o `administrador`). Algunas vistas — como el reporte de auditoría de gobernanza — son exclusivas para `administrador` . Intentar acceder sin el rol correcto responde con error 403 (acceso denegado).

3.6 Diagrama de gobernanza

El diagrama interactivo adjunto ([onest-gobernanza.html](#)) muestra estos 5 controles ubicados exactamente donde ocurren en el sistema: en el borde (SDK, validador, pseudonimización) y en el punto de consulta (RBAC, Privacy Guard).

4. Evidencia de cumplimiento

Criterio evaluado	Resultado
Protección de datos personales (Privacy by Design)	✓ Aprobado sin reservas
Resiliencia del pipeline (FastAPI + RabbitMQ + ClickHouse)	✓ Aprobado
Homologación visual (ONEST Digital Design System v1.0)	✓ Aprobado
Cobertura de pruebas automatizadas	✓ 12/12 pruebas exitosas

Fuente: Dossier de Auditoría Técnica y Evaluación de Cumplimiento (documento interno del proyecto).

5. Qué tenemos que hacer (próximos pasos)

La Fase 1 (MVP) está operativa y aprobada. Lo siguiente identificado para evolucionar la plataforma:

5.1 Ya resuelto en esta fase

- Tipografía corporativa (Montserrat + Inter) cargada correctamente
- Semáforo de salud técnica y métricas de cuentas inactivas visibles en el dashboard
- Modo oscuro automático para turnos nocturnos de operación (NOC), activo entre 20:00 y 06:00
- Sidebar de navegación vertical alineado al Design System

5.2 Pendiente para Fase 2

- **Selector de rango de fechas real:** hoy son 4 botones fijos (7/14/30/90 días); falta un date-picker con rango arbitrario si se necesita mayor granularidad.
- **Sistema de alertamiento proactivo:** no existe aún notificación en tiempo real cuando la latencia o la tasa de error superan un umbral crítico — hoy hay que entrar al dashboard para verlo.
- **Roles adicionales:** actualmente solo existen "ejecutivo" y "administrador"; si se requiere un rol de auditoría con acceso a identidad real bajo justificación, es un desarrollo de backend nuevo (rol + audit log), no solo de interfaz.
- **Confirmar alcance de responsables:** dos administradores en el equipo de TI tienen su alcance de rol marcado como "por confirmar" (Soporte y Servidores) — pendiente de definición organizacional, no técnica.

5.3 Recomendación

Ninguno de los pendientes bloquea el uso actual del sistema. Se recomienda priorizar el **sistema de alertamiento** primero, ya que reduce el tiempo de reacción ante incidentes técnicos, y dejar el rol de auditoría para cuando exista un caso de uso concreto que lo justifique (por su impacto en privacidad).